

Universidad Politécnica de Yucatán

Protección de Datos Personales

ACTIVIDAD #8

Evaluación y Tratamiento de Riesgos de Datos

Docente:	M.C. Francisco Javier Suárez Pech
Alumno:	Héctor J. Rayaromo
Matrícula:	2048731
Carrera:	TSU en Ciencia de Datos
Cuatrimestre:	6° Cuatrimestre
Actividad:	#8 - Evaluación y Tratamiento de Riesgos
Fecha:	22 de julio de 2026

1. Introducción

La gestión de riesgos de datos es un proceso fundamental dentro de cualquier organización que maneje información sensible. Según el estándar ISO/IEC 27001:2022, la evaluación y tratamiento de riesgos permite identificar, analizar y mitigar amenazas que puedan comprometer la confidencialidad, integridad y disponibilidad de los activos de información.

En el presente documento se aplica la metodología basada en activos, amenazas, vulnerabilidades e impactos (escala 1-5) sobre un escenario realista: una institución financiera con infraestructura crítica. Se desarrolla un análisis cuantitativo del nivel de riesgo ($\text{Riesgo} = \text{Probabilidad} \times \text{Impacto}$), se proponen controles del Anexo A de ISO 27001 y se definen planes de contingencia estructurados en tres fases: antes, durante y después del incidente.

2. Objetivo

Identificar, evaluar y proponer el tratamiento de los principales riesgos a los que se exponen los datos personales manejados por una institución financiera, aplicando controles de la norma ISO/IEC 27001:2022 y elaborando planes de contingencia para garantizar la continuidad del negocio.

3. Inventario de Activos

El primer paso en la evaluación de riesgos es identificar los activos de información críticos de la organización. La siguiente tabla muestra los principales activos evaluados en este análisis:

ID	Activo	Tipo	Ubicación
A-01	Servidor de BD con datos de clientes	Hardware/Software	Data Center Principal
A-02	Aplicación Web de Banca	Software	Servidor de Aplicaciones
A-03	Red Corporativa	Redes	LAN/WAN
A-04	Credenciales de acceso de usuarios	Información	Active Directory
A-05	Copias de seguridad (Backups)	Información	Sitio Alterno

4. Metodología de Evaluación

Se utiliza una metodología cuantitativa basada en la multiplicación de probabilidad por impacto. Ambas variables se evalúan en una escala del 1 al 5:

Nivel	Probabilidad	Impacto	Rango de Riesgo ($P \times I$)
Crítico	5	5	≥ 15
Alto	4	4	10 - 14
Medio	3	3	5 - 9
Bajo	2	2	1 - 4

Escala de Probabilidad: 1=Muy improbable, 2=Improbable, 3=Posible, 4=Probable, 5=Casi cierto.

Escala de Impacto: 1=Insignificante, 2=Menor, 3=Moderado, 4=Mayor, 5=Catastrófico.

5. Análisis Detallado de Riesgos

5.1 Amenaza 1: Acceso No Autorizado a la Base de Datos

Acceso no autorizado a la base de datos por credenciales débiles o robadas, permitiendo robo o alteración masiva de datos de clientes.

Elemento	Descripción
Activo afectado	A-01: Servidor de BD con datos de clientes
Vulnerabilidad	Contraseñas débiles y falta de MFA
Probabilidad (P)	4
Impacto (I)	5
Nivel de Riesgo (P×I)	20 (Crítico)
Tipo de riesgo	Confidencialidad / Integridad
Tratamiento	Mitigar

Controles ISO 27001 propuestos:

- ISO 27001 A.5.17 — Información de autenticación
- ISO 27001 A.8.5 — Autenticación segura (MFA obligatorio)
- Política de contraseñas robustas (mínimo 12 caracteres, rotación trimestral)
- Implementación de MFA para todos los accesos administrativos

Plan de contingencia:

- **Antes:** Auditorías trimestrales de contraseñas, logs de acceso centralizados en SIEM, alertas en tiempo real.
- **Durante:** Bloqueo inmediato de cuentas comprometidas, rotación de credenciales, aislamiento del segmento afectado.
- **Después:** Investigación forense, notificación a clientes según ISO 27001 A.5.26, refuerzo de controles.

5.2 Amenaza 2: Ransomware en Servidor de Aplicación Web

Ataque de ransomware que cifra la aplicación web de banca, interrumpiendo el servicio y exigiendo rescate por la recuperación de los datos.

Elemento	Descripción
Activo afectado	A-02: Aplicación Web de Banca
Vulnerabilidad	Falta de EDR y segmentación de red insuficiente
Probabilidad (P)	3
Impacto (I)	5
Nivel de Riesgo (P×I)	15 (Crítico)
Tipo de riesgo	Disponibilidad / Integridad
Tratamiento	Mitigar

Controles ISO 27001 propuestos:

- ISO 27001 A.8.7 — Protección contra malware (EDR/XDR)

- ISO 27001 A.8.20 — Seguridad de redes (segmentación y microsegmentación)
- ISO 27001 A.8.16 — Actividades de monitoreo continuo
- Whitelisting de aplicaciones y sandboxing de ejecutables

Plan de contingencia:

- **Antes:** Backups inmutables offline (regla 3-2-1), simulacros trimestrales de restauración, EDR en todos los endpoints.
- **Durante:** Aislar el servidor afectado, activar el BCP, conmutación a sitio alternativo, no pagar el rescate.
- **Después:** Restaurar desde backups limpios, RCA, actualizar controles, notificar a las autoridades.

5.3 Amenaza 3: Phishing Dirigido al Personal

Campaña de phishing dirigida a empleados para robar credenciales corporativas y obtener acceso a sistemas internos con datos sensibles.

Elemento	Descripción
Activo afectado	A-04: Credenciales de acceso de usuarios
Vulnerabilidad	Falta de capacitación y simulación de phishing
Probabilidad (P)	5
Impacto (I)	4
Nivel de Riesgo (P×I)	20 (Crítico)
Tipo de riesgo	Confidencialidad
Tratamiento	Mitigar

Controles ISO 27001 propuestos:

- ISO 27001 A.6.3 — Concientización, educación y capacitación
- ISO 27001 A.5.18 — Derechos de acceso (principio de mínimo privilegio)
- Campañas de simulación de phishing mensuales con métricas
- Filtros anti-phishing en correo (DMARC, DKIM, SPF)

Plan de contingencia:

- **Antes:** Entrenamiento continuo, simulacros de phishing, filtros avanzados de correo, MFA en todas las cuentas.
- **Durante:** Revocar credenciales comprometidas, análisis de correos recibidos, búsqueda de indicadores de compromiso (IOC).
- **Después:** RCA, capacitación dirigida al área afectada, monitoreo de uso indebido de credenciales.

5.4 Amenaza 4: Fallo de Red / Caída de Conectividad

Caída del servicio de Internet por falla del proveedor único de ISP, interrumpiendo el acceso a la banca en línea y servicios críticos.

Elemento	Descripción
Activo afectado	A-03: Red Corporativa
Vulnerabilidad	Único proveedor ISP sin redundancia
Probabilidad (P)	3
Impacto (I)	3
Nivel de Riesgo (P×I)	9 (Medio)
Tipo de riesgo	Disponibilidad
Tratamiento	Transferir / Mitigar

Controles ISO 27001 propuestos:

- ISO 27001 A.8.20 — Seguridad de redes (redundancia y segmentación)
- ISO 27001 A.5.30 — Preparación TIC para la continuidad del negocio
- Contrato con ISP secundario (redundancia geográfica)

- VPN IPsec para conexiones críticas y monitoreo SNMP/SLA de enlaces

Plan de contingencia:

- **Antes:** Doble enlace ISP con BGP, pruebas de failover mensuales, SLA estricto con proveedores.
- **Durante:** Conmutar a ISP secundario, activar modo degradado, comunicar a usuarios el estado del servicio.
- **Después:** Revisar SLA, documentar incidente, optimizar redundancia y topología de red.

5.5 Amenaza 5: Robo o Corrupción de Respaldos

Compromiso, robo o corrupción de las copias de seguridad, eliminando la capacidad de recuperación ante incidentes graves como ransomware o fallos de hardware.

Elemento	Descripción
Activo afectado	A-05: Copias de seguridad (Backups)
Vulnerabilidad	Backups sin cifrado y sin separación física
Probabilidad (P)	2
Impacto (I)	5
Nivel de Riesgo (P×I)	10 (Alto)
Tipo de riesgo	Confidencialidad / Disponibilidad
Tratamiento	Mitigar

Controles ISO 27001 propuestos:

- ISO 27001 A.5.10 — Aceptación, entrega y salida de información
- ISO 27001 A.8.13 — Copias de seguridad (regla 3-2-1)
- ISO 27001 A.8.24 — Uso de criptografía (AES-256 en reposo y tránsito)
- Almacenamiento inmutable (WORM) en la nube y geográficamente distribuido

Plan de contingencia:

- **Antes:** Cifrado de backups, pruebas de restauración trimestrales, ubicación geográficamente diversa, control de acceso físico y lógico.
- **Durante:** Activar respaldos en sitio alternativo, verificar integridad de copias mediante hash criptográfico.
- **Después:** Restauración verificada, análisis del incidente, actualización de procedimientos de backup.

6. Matriz Resumen de Riesgos

ID	Riesgo	P	I	Nivel	Tratamiento
R1	Acceso no autorizado BD	4	5	20 (Crítico)	Mitigar
R2	Ransomware	3	5	15 (Crítico)	Mitigar
R3	Phishing	5	4	20 (Crítico)	Mitigar
R4	Fallo de red	3	3	9 (Medio)	Transferir/Mitigar
R5	Robo/corrupción de backups	2	5	10 (Alto)	Mitigar

7. Mapa de Calor de Riesgos

El siguiente mapa de calor representa visualmente la ubicación de cada riesgo según su probabilidad e impacto:

	P=1	P=2	P=3	P=4	P=5
I=5			R2	R1	R3
I=4					
I=3			R4		
I=2					
I=1					

Nivel	Color	Acción requerida
Crítico (≥15)	Rojo	Tratamiento inmediato, aprobación del CISO
Alto (10-14)	Naranja	Tratamiento obligatorio en el siguiente trimestre
Medio (5-9)	Amarillo	Tratamiento planificado dentro del año fiscal
Bajo (1-4)	Verde	Aceptar o revisar anualmente

8. Conclusiones

- Los riesgos **R1 (Acceso no autorizado a BD)** y **R3 (Phishing)** se ubican en el nivel crítico (20) y requieren atención inmediata con aprobación del CISO y asignación de recursos prioritarios.
- El riesgo **R2 (Ransomware)**, aunque tiene probabilidad media, su impacto catastrófico lo sitúa también en nivel crítico, justificando la inversión en EDR/XDR y backups inmutables.
- El plan de contingencia se estructura en tres fases (antes, durante y después) alineado con el control ISO 27001 A.5.30, permitiendo una respuesta organizada y medible ante incidentes.
- Todos los controles propuestos están vinculados al Anexo A de ISO 27001:2022, lo que facilita la auditoría de certificación y el seguimiento de la implementación.
- Se recomienda una **revisión trimestral** de la matriz de riesgos y una actualización inmediata tras cualquier incidente o cambio significativo en la infraestructura.

- La combinación de controles preventivos (MFA, capacitación, cifrado), detectivos (SIEM, EDR) y correctivos (planes de contingencia) conforma una estrategia de defensa en profundidad efectiva.

9. Referencias

- ISO/IEC 27001:2022 — Sistemas de Gestión de Seguridad de la Información. Anexo A — Controles de referencia.
- ISO/IEC 27005:2022 — Directrices para la gestión de riesgos de seguridad de la información.
- NIST SP 800-30 Rev. 1 — Guide for Conducting Risk Assessments.
- Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP) — México.